DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

# Cuidarte+

## Informe de seguridad y calidad en el desarrollo de software

**ISY1102 - Seguridad y calidad en el desarrollo de software**
**Sección 001V**

**Ingeniería en Informática**

**Docente:** Juan Azocar

**Integrantes**
Cesar Estay
Aaron Lorca
Elian Barra

# INDICE

INDICE ..... 2
1. Introducción ..... 3
1.1 Contexto del software ..... 3
1.2 Propósito del plan de pruebas ..... 3
2. Criterios de calidad ..... 4
2.1 Criterios de calidad del producto ..... 4
2.2 Criterios de seguridad ..... 5
2.3 Criterios de cumplimiento normativo ..... 6
3. Plan de pruebas ..... 7
3.1 Estrategia de pruebas ..... 7
3.2 Tipos de prueba ..... 9
3.3 Criterios de aceptación ..... 10
3.4 Herramientas utilizadas ..... 10
4. Diseño de casos de prueba ..... 12
4.1 CP-01 Autenticación y gestión de sesión ..... 12
4.2 CP-02 Política de contraseñas y almacenamiento seguro ..... 13
4.3 CP-03 Control de acceso por rol ..... 14
4.4 CP-04 Gestión y descarga de documentos médicos ..... 15
4.5 CP-05 Registro de auditoría y eliminación lógica ..... 16
4.6 CP-06 Usabilidad y accesibilidad para adultos mayores ..... 17

# 1. Introducción

## 1.1 Contexto del software

Cuidarte+ es una plataforma web orientada a centros de salud para la gestión de pacientes, exámenes médicos y documentos clínicos. Corresponde a una aplicación multicapa cuyo frontend está construido en React y consume una API RESTful implementada en Node.js con Express, la cual opera sobre una base de datos PostgreSQL. El sistema contempla cuatro perfiles de usuario diferenciados: administrador, médico, paciente y usuario anónimo o visitante, cada uno con permisos acotados según las reglas de negocio definidas en la especificación de requerimientos de software.

La particularidad del producto no radica en su complejidad funcional, que se reduce esencialmente a operaciones CRUD sobre pacientes, exámenes y documentos, sino en la naturaleza de la información que administra. Los antecedentes clínicos, los resultados de exámenes y los documentos médicos adjuntos constituyen datos personales sensibles conforme a la legislación chilena vigente, lo que eleva significativamente el nivel de exigencia aplicable en materia de confidencialidad, control de acceso, trazabilidad y resguardo. A ello se suma que el alcance del proyecto declara una atención especial a la usabilidad para adultos mayores, segmento que impone requisitos adicionales de accesibilidad

## 1.2 Propósito del plan de pruebas

El presente plan de pruebas tiene por objeto establecer la estrategia, los criterios, los recursos y los casos de prueba necesarios para verificar que Cuidarte+ satisface los requerimientos funcionales y no funcionales especificados, así como los estándares de calidad y las obligaciones legales que le resultan aplicables. Se busca asegurar tres dimensiones de forma conjunta.

- **Conformidad funcional:** que cada requerimiento definido en la especificación se traduzca en un comportamiento observable y verificable del sistema.
- **Conformidad de calidad:** que los atributos no funcionales comprometidos **rendimiento**, **usabilidad**, **accesibilidad**, **disponibilidad** y **compatibilidad** alcancen los umbrales declarados.
- **Conformidad legal y normativa:** que el tratamiento de datos de salud cumpla con el marco regulatorio chileno y con los estándares técnicos de seguridad de la información adoptados por el proyecto.

El documento se organiza en cinco apartados. El primero corresponde a esta introducción. El segundo establece los criterios de calidad, seguridad y cumplimiento normativo que el software debe satisfacer, identificando los estándares técnicos y las normas legales aplicables. El tercero desarrolla el plan de pruebas propiamente tal, detallando la estrategia general, los tipos de prueba seleccionados con su justificación, los criterios de aceptación transversales y los recursos humanos, técnicos y de entorno requeridos. El cuarto presenta el diseño de seis casos de prueba representativos, trazados a los códigos de requerimiento de la especificación. El quinto analiza la cobertura y la coherencia del plan frente a los requerimientos y estándares, incorporando las observaciones detectadas sobre la especificación durante el análisis.

## 2. Criterios de calidad

Los criterios que se presentan a continuación se derivan de tres fuentes: los requerimientos no funcionales declarados en la especificación de requerimientos de software, el modelo de calidad de producto de la norma ISO/IEC 25010 y el marco legal chileno aplicable al tratamiento de datos de salud.

### 2.1 Criterios de calidad del producto

Se adopta ISO/IEC 25010 como referencia para clasificar los atributos de calidad exigibles, por cuanto proporciona un vocabulario común y permite verificar que ninguna dimensión relevante quede fuera del alcance de las pruebas.

- **Usabilidad y accesibilidad.** El sistema debe presentar tipografía legible, contraste suficiente, controles de tamaño adecuado y mensajes de error comprensibles, conforme a NFR-USAB-1 y NFR-USAB-3. El criterio de referencia externo es WCAG 2.1 en nivel AA, exigencia consistente con el foco declarado en adultos mayores y con la obligación de etiquetas ARIA y navegación por teclado establecida en el apartado 3.1.1 de la especificación.
- **Rendimiento.** Las operaciones CRUD simples deben responder en menos de 300 milisegundos bajo carga normal (NFR-PERF-1), la página principal debe cargar en menos de 2 segundos sobre conexión móvil promedio (NFR-PERF-2) y el sistema debe sostener 200 usuarios concurrentes por defecto (NFR-PERF-3). La subida y descarga de documentos no debe exceder los 10 segundos según el criterio de aceptación de RF-4.
- **Fiabilidad y disponibilidad.** Se compromete una disponibilidad objetivo de 99,5 % mensual (NFR-DIS-1), lo que admite aproximadamente 3 horas y 39 minutos de indisponibilidad al mes. Las actualizaciones deben ejecutarse en ventanas de mantenimiento con migración de datos segura (NFR-DIS-2).

- **Compatibilidad y portabilidad.** El sistema debe operar correctamente sobre las dos últimas versiones de Chrome, Firefox, Safari y Edge (NFR-COMPAT-1) y comportarse de forma responsiva en móviles y tablets (NFR-COMPAT-2).
- **Mantenibilidad.** Aunque no se declara de forma explícita en la especificación, se incorpora como criterio la existencia de una colección Swagger con pruebas básicas y cobertura de los endpoints críticos, exigida en el apartado 3.1.2, dado que constituye la base para la ejecución de pruebas de regresión automatizadas.

## 2.2 Criterios de seguridad

La especificación define nueve requerimientos de seguridad (NFR-SEG-1 a NFR-SEG-9) que se agrupan en cuatro criterios verificables.

- **Protección de datos en tránsito y en reposo.** Todas las comunicaciones deben emplear TLS y los datos sensibles deben encontrarse cifrados en reposo. Las contraseñas deben almacenarse mediante hashing con bcrypt, nunca en texto plano ni con algoritmos reversibles.
- **Control de acceso.** La autorización debe resolverse en el backend y no únicamente en la capa de presentación, de modo que ocultar una opción de menú en el frontend no sea la única barrera frente a un acceso no autorizado. La gestión de sesión se realiza mediante JWT de corta vigencia con refresh token y revocación efectiva al cerrar sesión.
- **Robustez frente a ataques conocidos.** El sistema debe resistir inyección SQL, cross-site scripting y cross-site request forgery, mediante validación y saneamiento de entrada en el servidor para todos los endpoints. Se adopta como referencia el OWASP Top 10 y el estándar OWASP ASVS para estructurar la verificación.
- **Trazabilidad y recuperación.** Toda acción crítica debe generar un registro de auditoría (RF-5.1) y deben existir políticas de respaldo y recuperación definidas y probadas (NFR-SEG-7). La gestión de logs debe ser segura, lo que implica que los registros no expongan datos clínicos ni credenciales.

## 2.3 Criterios de cumplimiento normativo

El requerimiento NFR-SEG-8 exige genéricamente el cumplimiento de normativas de protección de datos personales. Dado que el sistema opera en Chile y utiliza el RUT como identificador, ese cumplimiento se concreta en el siguiente marco.

- **Ley N° 19.628 sobre protección de la vida privada.** Constituye el estatuto actualmente aplicable en materia de tratamiento de datos personales, estableciendo los conceptos, los derechos de los titulares y los deberes del responsable del tratamiento.
- **Ley N° 21.719 sobre protección y tratamiento de datos personales.** Publicada el 13 de diciembre de 2024, reescribe estructuralmente la Ley N° 19.628 y crea la Agencia de Protección de Datos Personales. Su entrada en vigor está prevista para el 1 de diciembre de 2026. Califica expresamente los datos relativos a la salud, el perfil biológico y los datos biométricos como datos sensibles, elevando las exigencias de consentimiento y confidencialidad, incorpora los derechos ARCO ampliados, obliga a notificar las brechas de seguridad y establece un régimen de sanciones de hasta 20.000 unidades tributarias mensuales. Dado que Cuidarte+ se encuentra en desarrollo dentro del período de transición, el plan de pruebas verifica el cumplimiento anticipado de estas obligaciones, evitando una readecuación posterior de mayor costo.
- **Ley N° 20.584 sobre derechos y deberes del paciente.** Regula la reserva de la ficha clínica y consagra el derecho del paciente a acceder a su información de salud, lo que respalda directamente los requerimientos RF-4.1 y RF-4.2 y obliga a que la funcionalidad de consulta y descarga sea efectiva y no meramente declarativa.
- **ISO/IEC 27001 e ISO/IEC 27002.** Se adoptan como marco de controles de seguridad de la información, particularmente en lo referido a control de acceso, criptografía, registro de eventos y continuidad operacional.
- **WCAG 2.1 nivel AA.** Se adopta como criterio objetivo de accesibilidad, en tanto la especificación exige atención a usuarios adultos mayores sin definir un umbral medible.

En consecuencia, un caso de prueba se considera fallido no solo cuando el sistema entrega un resultado funcional incorrecto, sino también cuando el resultado es correcto, pero se obtiene por una vía que vulnera alguno de los criterios anteriores.

# 3. Plan de pruebas

## 3.1 Estrategia de pruebas

Se adopta un enfoque mixto. Las pruebas de seguridad, de regresión funcional y de rendimiento se automatizan, dado que deben repetirse en cada iteración y requieren volumen o precisión de medición que la ejecución manual no garantiza. Las pruebas de usabilidad, accesibilidad asistida y exploratorias se ejecutan de forma manual, porque evalúan percepción, comprensión y facilidad de uso, dimensiones que ninguna herramienta automatizada puede sustituir por completo.

La justificación de este enfoque es económica y técnica a la vez: automatizar la totalidad de las pruebas resultaría desproporcionado para el tamaño del proyecto, mientras que ejecutarlas todas manualmente impediría verificar los umbrales de concurrencia comprometidos y haría inviable la detección temprana de regresiones.

El proceso se organiza en cuatro etapas secuenciales con retroalimentación continua.

- **Etapa 1 (Pruebas unitarias y de componentes).** Ejecutadas por el equipo de desarrollo sobre la lógica de negocio del backend y los componentes del frontend, integradas al flujo de integración continua.
- **Etapa 2 (Pruebas de integración y de API).** Verificación de los endpoints RESTful sobre la colección Swagger exigida en el apartado 3.1.2 de la especificación, cubriendo la comunicación entre frontend, backend y base de datos.
- **Etapa 3 (Pruebas de sistema, seguridad y rendimiento).** Ejecutadas sobre un ambiente de calidad equivalente a producción, incluyen el análisis de vulnerabilidades y las pruebas de carga contra los umbrales de NFR-PERF.
- **Etapa 4 (Pruebas de aceptación y usabilidad).** Validación con usuarios representativos, incluyendo al menos cinco adultos mayores conforme al criterio de aceptación del apartado 3.1.1, y verificación final de cumplimiento normativo.

La priorización se establece por riesgo, considerando el impacto de una falla sobre datos sensibles y la probabilidad de ocurrencia.

- **Prioridad crítica:** autenticación, autorización por rol, cifrado en tránsito y registro de auditoría. Una falla en cualquiera de estos puntos expone datos clínicos y constituye incumplimiento legal directo.
- **Prioridad alta:** operaciones CRUD sobre pacientes y exámenes, carga y descarga de documentos, eliminación lógica con confirmación.
- **Prioridad media:** rendimiento bajo carga, accesibilidad y compatibilidad entre navegadores.
- **Prioridad baja:** aspectos cosméticos de interfaz que no afecten la comprensión ni la operación del sistema.

Los criterios de entrada y salida del ciclo de pruebas son los siguientes.

- **Criterios de entrada:** especificación de requerimientos aprobada y versionada; ambiente de calidad desplegado con datos de prueba anonimizados; colección Swagger disponible; casos de prueba revisados por el equipo.
- **Criterios de salida:** cero defectos abiertos de severidad crítica o alta; cien por ciento de los casos de prioridad crítica ejecutados y aprobados; umbrales de NFR-PERF cumplidos; checklist de auditoría de seguridad sin hallazgos críticos, conforme al criterio de aceptación del apartado 3.3.1; informe de pruebas firmado por el responsable de calidad.

## 3.2 Tipos de prueba

| Tipo de prueba | Qué verifica en Cuidarte+ | Justificación |
|---|---|---|
| Funcionales (caja negra) | Que cada requerimiento RF-1 a RF-5 produzca el comportamiento especificado: login, registro, CRUD de pacientes y exámenes, adjunto y descarga de documentos, auditoría. | Son la base de la verificación: sin conformidad funcional, el resto de los atributos carece de sentido. |
| De integración | La comunicación entre el frontend React, la API Express y PostgreSQL, incluyendo el manejo de CORS y la propagación de errores. | La arquitectura multicapa concentra el riesgo en las interfaces entre capas, no dentro de cada una. |
| De seguridad | Control de acceso por rol, resistencia a inyección SQL, XSS y CSRF, hashing bcrypt, vigencia y revocación de JWT, cifrado TLS. | La información administrada es dato sensible; una falla aquí implica incumplimiento legal, no solo defecto técnico. |
| De rendimiento y carga | Tiempos de respuesta CRUD bajo 300 ms, carga inicial bajo 2 s, 200 usuarios concurrentes y subida o descarga de documentos bajo 10 s. | Los umbrales están declarados numéricamente en NFR-PERF, por lo que son verificables de forma objetiva y exigible. |
| De usabilidad y accesibilidad | Legibilidad, contraste, tamaño de controles, navegación por teclado, etiquetas ARIA y claridad del flujo paciente a exámenes (NFR-USAB-4). | El alcance declara foco explícito en adultos mayores; sin esta verificación el sistema puede ser funcionalmente correcto e inutilizable para su público objetivo. |
| De compatibilidad | Comportamiento sobre las dos últimas versiones de Chrome, Firefox, Safari y Edge, en escritorio, tablet y móvil. | La especificación compromete multiplataforma; la responsividad no puede asumirse por el uso de frameworks. |
| De regresión | Reejecución automatizada del conjunto crítico ante cada cambio de código. | Permite confirmar que las correcciones no introduzcan defectos nuevos en funcionalidades ya aprobadas. |
| De recuperación | Ejecución y restauración de respaldos conforme a NFR-SEG-7 y NFR-DIS-2. | Un respaldo que nunca se restaura no es un respaldo verificado; la disponibilidad de 99,5 % lo exige. |

### 3.3 Criterios de aceptación

Con independencia del caso de prueba particular, se establecen los siguientes criterios de aceptación aplicables a todo el conjunto.

- **Funcionales:** el resultado obtenido coincide con el resultado esperado; el sistema no presenta errores no controlados ni trazas técnicas expuestas al usuario; toda operación de eliminación es lógica y solicita confirmación previa, conforme al criterio de aceptación de RF-3.
- **De seguridad:** ninguna respuesta del sistema expone credenciales, identificadores internos ni datos clínicos de terceros; todo acceso denegado retorna un código HTTP adecuado sin revelar la existencia del recurso; la validación se ejecuta en el servidor aun cuando exista validación en el cliente.
- **No funcionales:** los tiempos medidos se ubican bajo los umbrales de NFR-PERF en al menos el percentil 95 de las mediciones; la interfaz mantiene su comportamiento en los navegadores y resoluciones comprometidos.
- **De reglas de negocio:** el paciente conserva permisos exclusivamente de lectura sobre su propia información (RB-1); el administrador dispone de acceso completo (RB-2); el acceso a información clínica por parte de un médico queda registrado en auditoría.

**De cumplimiento:** toda acción crítica genera su registro de auditoría con identificación de usuario, acción, recurso afectado y marca temporal; los datos de prueba utilizados son ficticios o anonimizados, sin emplear en ningún caso información clínica real.

### 3.4 Herramientas utilizadas

**Recursos Humanos**: El equipo de pruebas se organiza en los siguientes roles, que pueden ser asumidos por menos personas de las indicadas según la disponibilidad del proyecto.

| Rol | Responsabilidad |
|---|---|
| Líder de calidad (QA Lead) | Define la estrategia, aprueba los criterios de salida y consolida el informe final de pruebas. |
| Analista de pruebas | Diseña y ejecuta los casos funcionales y no funcionales, registra defectos y verifica correcciones. |
| Analista de seguridad | Ejecuta el checklist de auditoría, las pruebas de penetración y la verificación de controles criptográficos. |
| Desarrollador backend y frontend | Implementa las pruebas unitarias, corrige los defectos reportados y mantiene el entorno de integración continua. |
| Especialista en usabilidad | Coordina y modera las sesiones con usuarios representativos, incluidos adultos mayores. |

| Rol | Responsabilidad |
|---|---|
| Usuarios representativos | Participan en las pruebas de aceptación y usabilidad; se requieren al menos cinco perfiles de adulto mayor. |

**Recursos técnicos**: Las herramientas se seleccionan por su compatibilidad con el stack declarado en la especificación (React, Express, PostgreSQL) y por su disponibilidad en versiones de código abierto.

| Herramienta | Tipo de prueba | Fundamento de su uso |
|---|---|---|
| Jest y Supertest | Unitarias y de API | Ejecutan pruebas sobre la lógica Node.js y permiten invocar los endpoints Express sin levantar un servidor externo. |
| React Testing Library | Componentes y accesibilidad básica | Verifica el comportamiento de los componentes desde la perspectiva del usuario y detecta ausencia de etiquetas accesibles. |
| Postman y Newman | Integración y regresión de API | Aprovechan la colección Swagger exigida por la propia especificación y permiten ejecutarla de forma automatizada en el pipeline. |
| k6 o Apache JMeter | Rendimiento y carga | Permiten simular los 200 usuarios concurrentes de NFR-PERF-3 y medir percentiles de tiempo de respuesta. |
| OWASP ZAP | Seguridad | Realiza análisis dinámico de vulnerabilidades sobre la aplicación desplegada, cubriendo el OWASP Top 10. |
| sqlmap | Seguridad (inyección SQL) | Verifica de forma dirigida la resistencia de los endpoints a inyección, complementando el análisis general de ZAP. |
| axe-core y Lighthouse | Accesibilidad y rendimiento web | Entregan métricas objetivas de conformidad WCAG 2.1 AA y de tiempo de carga en condiciones móviles. |
| BrowserStack o emulación de navegador | Compatibilidad | Permite cubrir las dos últimas versiones de los cuatro navegadores comprometidos sin mantener equipos físicos. |
| Jira o GitHub Issues | Gestión de defectos | Registra, prioriza y da seguimiento a los hallazgos con trazabilidad al caso de prueba y al requerimiento. |

**Entorno de pruebas**: Se contemplan tres ambientes diferenciados. El ambiente de desarrollo, local para cada integrante, donde se ejecutan las pruebas unitarias antes de integrar código. El ambiente de calidad o QA, con configuración equivalente a producción en versiones de Node.js, PostgreSQL y certificados TLS, poblado exclusivamente con datos ficticios y sobre el cual se ejecutan las pruebas de integración, seguridad, rendimiento y usabilidad. El ambiente de producción, donde únicamente se ejecutan verificaciones de humo posteriores al despliegue, sin pruebas destructivas ni de carga. La separación es especialmente relevante en este proyecto: ejecutar pruebas de penetración o de carga sobre datos clínicos reales configuraría por sí misma un tratamiento indebido de datos sensibles.

## 4. Diseño de casos de prueba

Se presentan seis casos de prueba representativos, seleccionados de modo que cubran las distintas familias de requerimientos de la especificación: autenticación, registro y políticas de credenciales, autorización por rol, gestión documental con rendimiento asociado, auditoría y usabilidad. Cada caso se traza al código de requerimiento correspondiente.

### 4.1 CP-01 Autenticación y gestión de sesión

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-01** | **Autenticación válida, fallida y revocación de token** | RF-1.1, RF-1.2, NFR-SEG-9, NFR-SEG-1 |
| **DESCRIPCIÓN** | | |
| Verificar que el sistema autentica correctamente a un usuario registrado, emite un JWT de corta vigencia, rechaza credenciales inválidas sin revelar información y revoca efectivamente la sesión al cerrar sesión | | |
| **PRECONDICIONES** | | |
| Existe un usuario registrado y activo en el ambiente de QA.<br>El sistema se encuentra desplegado con certificado TLS válido.<br>El usuario no tiene una sesión activa previa. | | |
| **PASOS** | | |
| 1. Acceder a la página de login mediante HTTPS.<br>2. Ingresar nombre de usuario y contraseña válidos y confirmar.<br>3. Inspeccionar el token recibido y su tiempo de expiración.<br>4. Cerrar sesión desde la interfaz.<br>5. Reenviar una petición a un endpoint protegido utilizando el token anterior.<br>6. Repetir el paso 2 con contraseña incorrecta y observar el mensaje devuelto. | | |
| **RESULTADO ESPERADO** | | |
| El login válido retorna HTTP 200 y un JWT firmado con expiración de corta vigencia.<br>Tras el cierre de sesión, la reutilización del token retorna HTTP 401.<br>Las credenciales inválidas retornan un mensaje genérico, sin distinguir si el error está en el usuario o en la contraseña. | | |

| CRITERIO DE ACEPTACIÓN |
|---|
| El token se transmite exclusivamente sobre TLS y no se almacena en texto plano accesible por scripts.<br>La respuesta de error no permite enumerar usuarios existentes.<br>La revocación es efectiva de inmediato, sin depender de la expiración natural del token. |
| **DATOS DE PRUEBA** |
| Válido: usuario "medico.prueba" / contraseña "Qa#Cuidarte2026".<br>Inválido: usuario "medico.prueba" / contraseña "Qa#Cuidarte2025".<br>Inexistente: usuario "usuario.inexistente" / cualquier contraseña. |

## 4.2 CP-02 Política de contraseñas y almacenamiento seguro

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-02** | Validación de política de contraseñas y hashing bcrypt | RF-2.1, NFR-SEG-2, restricción 2.4 de la especificación |
| **DESCRIPCIÓN** | | |
| Verificar que el registro de usuarios rechaza contraseñas que no cumplen la política definida y que la contraseña aceptada se almacena mediante hashing bcrypt y nunca en texto plano. | | |
| **PRECONDICIONES** | | |
| El formulario de registro se encuentra habilitado para usuarios anónimos.<br>Se dispone de acceso de consulta a la base de datos del ambiente de QA.<br>La política por defecto exige 12 caracteres con mayúsculas, minúsculas, número y símbolo. | | |
| **PASOS** | | |
| 1. Acceder al formulario de registro como usuario anónimo.<br>2. Intentar registrar con cada contraseña no conforme del conjunto de datos de prueba.<br>3. Registrar con una contraseña conforme y confirmar el registro.<br>4. Consultar el registro creado en la tabla de usuarios.<br>5. Verificar el rol asignado por defecto al nuevo usuario.<br>6. Repetir el paso 3 enviando la petición directamente a la API, omitiendo la validación del frontend. | | |
| **RESULTADO ESPERADO** | | |
| Las contraseñas no conformes son rechazadas con un mensaje que indica el requisito incumplido.<br>La contraseña conforme permite completar el registro y el usuario accede con rol "paciente" por defecto.<br>El valor almacenado en base de datos corresponde a un hash bcrypt con sal, identificable por su prefijo, y no a la contraseña ingresada. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| La validación se aplica también cuando la petición se envía directamente a la API, confirmando validación del lado del servidor.<br>En ningún punto del flujo, incluidos los logs de aplicación, aparece la contraseña en texto plano.<br>El rol asignado por defecto nunca es administrador ni médico. | | |
| **DATOS DE PRUEBA** | | |
| No conforme por longitud: "Abc1#xyz".<br>No conforme por ausencia de símbolo: "Cuidarte2026AB".<br>No conforme por ausencia de mayúscula: "cuidarte#2026a".<br>Conforme: "Cu1darte+Qa#26". | | |

## 4.3 CP-03 Control de acceso por rol

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-03** | **Acceso no autorizado a información clínica de terceros** | RF-4.1, RB-1, NFR-SEG-4, NFR-SEG-5 |
| **DESCRIPCIÓN** | | |
| Verificar que un usuario con rol paciente no puede acceder a los exámenes ni documentos de otro paciente, aun manipulando directamente el identificador del recurso en la petición. | | |
| **PRECONDICIONES** | | |
| Existen dos pacientes registrados, identificados como Paciente A y Paciente B, cada uno con al menos un examen asociado.<br>El Paciente A dispone de credenciales válidas y sesión iniciada.<br>Se conoce el identificador del examen del Paciente B. | | |
| **PASOS** | | |
| 1. Iniciar sesión con las credenciales del Paciente A.<br>2. Consultar la vista de exámenes propios y registrar el identificador mostrado.<br>3. Modificar manualmente el identificador en la URL para apuntar al examen del Paciente B.<br>4. Repetir la operación invocando directamente el endpoint de la API con el token del Paciente A.<br>5. Intentar la descarga del documento asociado al examen del Paciente B.<br>6. Intentar una operación de escritura sobre el propio examen del Paciente A. | | |
| **RESULTADO ESPERADO** | | |
| Toda petición del Paciente A sobre recursos del Paciente B es denegada con HTTP 403 o 404.<br>La respuesta no incluye ningún dato clínico del Paciente B, ni siquiera de forma parcial en mensajes de error.<br>La operación de escritura sobre el propio examen también es denegada, conforme a RB-1. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| La denegación se produce en el backend y no depende de que la interfaz oculte la opción.<br>El intento de acceso no autorizado queda registrado en la auditoría del sistema.<br>Ninguna respuesta permite inferir la existencia o el contenido del recurso ajeno. | | |
| **DATOS DE PRUEBA** | | |
| Paciente A: RUT 11.111.111-1, examen con identificador EX-1001.<br>Paciente B: RUT 22.222.222-2, examen con identificador EX-1002.<br>Token JWT válido correspondiente al Paciente A. | | |

## 4.4 CP-04 Gestión y descarga de documentos médicos

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-04** | **Carga, validación de formato y descarga de documento clínico** | RF-4.2, RF-4.3, RF-4.4, criterio de aceptación de RF-4 |
| **DESCRIPCIÓN** | | |
| Verificar que un médico puede adjuntar un documento en los formatos permitidos, que el sistema rechaza archivos no permitidos validando su tipo real, que el documento queda almacenado en storage interno con referencia en base de datos, y que la operación no excede los 10 segundos. | | |
| **PRECONDICIONES** | | |
| Existe un usuario con rol médico y un paciente con un examen registrado.<br>El storage interno se encuentra disponible con espacio suficiente.<br>Se dispone de un cronómetro o de la medición del panel de red del navegador. | | |
| **PASOS** | | |
| 1. Iniciar sesión como médico y acceder al examen del paciente.<br>2. Adjuntar un archivo PDF válido y medir el tiempo total de la operación.<br>3. Intentar adjuntar un archivo ejecutable renombrado con extensión .pdf.<br>4. Verificar en base de datos que exista la referencia al documento almacenado.<br>5. Iniciar sesión como el paciente propietario y descargar el documento, midiendo el tiempo.<br>6. Verificar que el archivo descargado es íntegro y legible. | | |
| **RESULTADO ESPERADO** | | |
| El PDF válido se adjunta correctamente y queda referenciado en la base de datos apuntando al storage interno.<br>El archivo con extensión falsificada es rechazado tras la validación de tipo real de contenido.<br>La subida y la descarga se completan en menos de 10 segundos cada una.<br>El archivo descargado coincide íntegramente con el original. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| La validación de formato considera el contenido del archivo y no únicamente su extensión.<br>El documento no queda accesible mediante una URL pública predecible ni sin autenticación.<br>Tanto la subida como la descarga generan su registro de auditoría conforme a RF-5.1. | | |
| **DATOS DE PRUEBA** | | |
| Archivo válido: examen_sangre.pdf, 2 MB.<br>Archivo con extensión falsificada: payload.exe renombrado como informe.pdf.<br>Archivo de formato no permitido: resultado.zip. | | |

## 4.5 CP-05 Registro de auditoría y eliminación lógica

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-05** | **Trazabilidad de acción crítica con eliminación lógica confirmada** | RF-3.3, RF-5.1, NFR-SEG-6, criterio de aceptación de RF-3 |
| **DESCRIPCIÓN** | | |
| Verificar que la eliminación de un examen médico solicita confirmación previa, se ejecuta como eliminación lógica conservando el dato en base de datos, y genera un registro de auditoría completo consultable por el administrador. | | |
| **PRECONDICIONES** | | |
| Existe un examen médico registrado con al menos un documento asociado.<br>Se dispone de un usuario con rol médico y de un usuario con rol administrador.<br>La tabla de auditoría se encuentra habilitada. | | |
| **PASOS** | | |
| 1. Iniciar sesión como médico y ubicar el examen a eliminar.<br>2. Ejecutar la acción de eliminación y observar si se solicita confirmación.<br>3. Cancelar la primera vez y verificar que el examen permanece visible.<br>4. Repetir la acción y confirmar la eliminación.<br>5. Consultar en base de datos el estado del registro eliminado.<br>6. Iniciar sesión como administrador y revisar el módulo de auditoría. | | |
| **RESULTADO ESPERADO** | | |
| El sistema solicita confirmación antes de proceder y respeta la cancelación.<br>Tras confirmar, el examen deja de mostrarse en la interfaz, pero el registro permanece en base de datos marcado como eliminado.<br>La auditoría registra usuario, acción, recurso afectado y marca temporal de la operación. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| No existe eliminación física del registro ni del documento asociado.<br>El registro de auditoría es inmutable para los roles médico y paciente.<br>Los logs no exponen el contenido clínico del examen eliminado, solo su identificador. | | |
| **DATOS DE PRUEBA** | | |
| Examen EX-1003, asociado al Paciente A, con documento adjunto.<br>Usuario médico: "medico.prueba".<br>Usuario administrador: "admin.prueba". | | |

## 4.6 CP-06 Usabilidad y accesibilidad para adultos mayores

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-06** | **Verificación de accesibilidad y flujo de consulta de exámenes** | NFR-USAB-1, NFR-USAB-2, NFR-USAB-4, NFR-COMPAT-2, apartado 3.1.1 |
| **DESCRIPCIÓN** | | |
| Verificar que la interfaz cumple criterios objetivos de accesibilidad y que usuarios adultos mayores logran completar sin bloqueos el flujo de acceso al paciente y posterior visualización de sus exámenes médicos. | | |
| **PRECONDICIONES** | | |
| Se dispone de cinco usuarios representativos mayores de 65 años.<br>El ambiente de QA está poblado con datos ficticios.<br>Se cuenta con axe-core o Lighthouse configurado sobre el frontend. | | |
| **PASOS** | | |
| 1. Ejecutar el análisis automatizado de accesibilidad sobre las páginas de login, dashboard y visualización de exámenes.<br>2. Verificar la razón de contraste y el tamaño de tipografía y de los controles interactivos.<br>3. Recorrer el flujo completo utilizando exclusivamente el teclado.<br>4. Solicitar a cada usuario representativo que inicie sesión, ubique un paciente y consulte sus exámenes, sin asistencia.<br>5. Registrar tiempos de ejecución, errores cometidos y puntos de duda o bloqueo.<br>6. Repetir el flujo en un dispositivo móvil y en una tablet. | | |
| **RESULTADO ESPERADO** | | |
| El análisis automatizado no arroja incumplimientos de nivel AA de WCAG 2.1.<br>El flujo completo es navegable por teclado, con foco visible y orden lógico.<br>Los cinco usuarios completan el flujo sin bloqueos mayores.<br>El flujo respeta el orden exigido por NFR-USAB-4: primero se accede al paciente y luego a sus exámenes. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| La razón de contraste alcanza al menos 4,5 a 1 para texto normal.<br>Los controles interactivos disponen de un área táctil suficiente para su uso en pantallas táctiles.<br>Los mensajes de error son comprensibles y orientan sobre la acción correctiva, conforme a NFR-USAB-3.<br>No se registran bloqueos que impidan completar la tarea en ninguno de los tres dispositivos. | | |
| **DATOS DE PRUEBA** | | |
| Cinco usuarios representativos, con distintos niveles de familiaridad tecnológica.<br>Credenciales de prueba entregadas impresas en tipografía de tamaño estándar.<br>Dispositivos: notebook 1366x768, tablet 10 pulgadas y móvil 360x800. | | |